

Авторизация, биллинг и учётные данные пользователей

10_Авторизация_биллинг_и_учётные_данные.md

Дата: 02.09.2026.

Документ фиксирует правовые последствия ввода системы учётных записей, лимитов и тарификации. Дополняет 09_Модель_сервиса_B2B_против_self-serve.md (модель предоставления сервиса) и 07_Соответствие_приказу_PKN_140.md.

1. Главный риск: учётные записи — это шаг в сторону self-serve

Документ 09 показал: переход к self-serve меняет вашу роль с лица, осуществляющего обработку по поручению, на **оператора**, у которого нет собственного правового основания обработки данных третьих лиц, упомянутых в загружаемых документах.

Сама по себе система учётных записей эту границу **не пересекает**. Пересекают её две конкретные функции:

Функция	Последствие
Открытая саморегистрация (/signup для любого)	Пользователь без договора → заимствовать основание не у кого → вы оператор
Онлайн-оплата картой	Обслуживает саморегистрацию; с потребителем-физицом ограничение ответственности ничтожно (ст. 16 ЗоЗПП)

[ЗАКОН] Ч. 3 ст. 6 152-ФЗ допускает обработку по поручению оператора без получения собственного согласия. Конструкция работает только при наличии оператора-заказчика, у которого основание есть. Анонимный самозарегистрировавшийся пользователь таким заказчиком не является.

1.1. Обязательное архитектурное ограничение

Публичного эндпоинта регистрации в системе быть не должно.

Учётная запись создаётся исключительно одним из двух способов:

- root создаёт аккаунт и его администратора** — после заключения договора поручения обработки ПДн (шаблон — документ 03) с организацией-заказчиком;
- администратор создаёт подпользователя** внутри своего аккаунта, в пределах plans.max_users — эти лица являются работниками оператора-заказчика и действуют в рамках его поручения.

Технически: вместо POST /signup — POST /invite/accept по одноразовому токenu, выпущенному root или администратором.

[РЕКОМЕНДАЦИЯ] Договор поручения должен прямо называть подпользователей: заказчик подтверждает, что лица, которым его администратор выдаёт доступ, уполномочены им на передачу документов в обработку. Без этой оговорки администратор фактически расширяет круг обрабатываемых лиц в одностороннем порядке, а вы об этом не знаете.

[СПОРНО] Если саморегистрация всё же понадобится, единственная рабочая конструкция — договор присоединения (ст. 428 ГК) в форме оферты с заверениями по ст. 431.2 ГК; полный разбор и его ограничения — в разделе 2.2 документа 09. Решение принимать до написания кода, а не после.

2. База пользователей — самостоятельная ИСПДн

Хеширование пароля защищает пароль. Оно **не выводит базу из-под 152-ФЗ**: адрес электронной почты является персональными данными сам по себе.

Следствие: на базу учётных записей распространяются те же требования, что и на обрабатываемые документы.

Требование	Основание	Что делать
Размещение на территории РФ	Ч. 5 ст. 18 152-ФЗ	БД в том же контуре, что фронтенд и бэкенд (см. 01)
Внесение в Перечень обрабатываемых ПДн	Приказ РКН № 140	Добавить категорию «данные учётных записей пользователей сервиса»
Указание в уведомлении РКН	Ст. 22 152-ФЗ	Обновить данные по документу 04
Определение срока хранения	П. 7 ч. 1 ст. 5 152-ФЗ	Установить и задокументировать; см. п. 4 ниже
Согласие на обработку при создании учётной записи	Ст. 9 152-ФЗ	Форма принятия при активации приглашения

2.1. Категории обрабатываемых данных учётных записей

Подлежат внесению в Перечень:

- адрес электронной почты (идентификатор и канал восстановления доступа);
- хеш пароля (argon2id) — производная от аутентификационных данных;
- принадлежность к организации-заказчику и роль;
- журнал использования сервиса, связанный с идентификатором пользователя.

[РЕКОМЕНДАЦИЯ] Не собирать ФИО, телефон и должность, пока в них нет функциональной необходимости. Каждое лишнее поле расширяет перечень, объём уведомления в РКН и последствия утечки, не давая продукту ничего.

3. Журнал использования как журнал событий безопасности

Таблица `usage_records` фиксирует, какой пользователь какой документ и когда передал в обработку. Это одновременно биллинговая и **защитная** запись.

[ЗАКОН] Таблица разграничения ответственности в документе 09 относит «регистрацию событий безопасности приложения» и «аутентификацию и разграничение доступа в приложении» к вашей зоне ответственности. Аттестат провайдера их не закрывает.

Практическое следствие: при инциденте у заказчика (документ 08 описывает разбор компрометации токена) журнал — единственный источник ответа на вопрос, чья учётная запись передала конкретный документ.

Требования к журналу:

- запись не удаляется и не изменяется задним числом;
- срок хранения — не менее срока действия договора поручения плюс срок исковой давности;
- в журнал **не попадает содержимое документов** — только имя файла, объём в знаках и метрики. Иначе журнал сам становится хранилищем ПДн заказчика с соответствующим режимом защиты.

[РЕКОМЕНДАЦИЯ] Проверить, что имя файла не является само по себе утечкой («Иванов И_И паспорт.docx»). Либо хранить хеш имени, либо предупредить заказчика в договоре, что имена файлов журналируются.

4. Срок хранения и удаление

[ЗАКОН] П. 7 ч. 1 ст. 5 152-ФЗ: данные хранятся не дольше, чем этого требует цель обработки. Ч. 4 ст. 21: при достижении цели обработка прекращается, данные уничтожаются.

Данные	Предлагаемый срок	Обоснование
Учётная запись	Срок действия договора + 30 дней	Возможность восстановления доступа при продлении
Журнал использования	Срок договора + срок исковой давности	Разрешение споров по счетам, разбор инцидентов
Таблица соответствий (mapping)	Не хранится на сервере	Отдаётся заказчику, у вас не остаётся — см. 05

Последняя строка — существенная. Хранение mapping на вашей стороне означало бы хранение ключа восстановления исходных персональных данных, что резко повышает последствия утечки. Действующая архитектура его не хранит; **при вводе учётных записей возникнет соблазн «сохранять историю обработок для удобства пользователя» — этого делать нельзя.**

4.1. Уничтожение требует средства с оценкой соответствия

[ЗАКОН] П. 3.1 ч. 2 ст. 19 152-ФЗ (введён ФЗ от 08.08.2024 № 233-ФЗ): для уничтожения персональных данных должны применяться **прошедшие оценку соответствия средства защиты информации, в составе которых реализована функция уничтожения информации.**

До появления базы данных это требование затрагивало только удаление задания из оперативной памяти. **С вводом постоянного хранилища оно распространяется на новые операции, которых раньше не было:**

- удаление учётной записи по истечении срока из таблицы п. 4;
- чистка журнала использования по истечении срока хранения;
- исполнение требования субъекта об удалении (ч. 3 ст. 14, ч. 5 ст. 21).

Существенно, что DELETE в СУБД **не уничтожает данные физически**: страница остаётся на диске до перезаписи, запись сохраняется в WAL/журнале транзакций, в резервных копиях и в файловой системе. Формально исполненное удаление при этом не является уничтожением в смысле п. 3 ст. 3 Закона.

[РЕКОМЕНДАЦИЯ] До первых удалений по сроку:

1. выбрать средство с оценкой соответствия, реализующее функцию уничтожения (либо получить от провайдера подтверждение, что такое средство применяется на его стороне — это часть матрицы разграничения ответственности из документа 09);
2. включить в порядок уничтожения обработку резервных копий: копия, содержащая удалённые данные, должна либо уничтожаться по тому же сроку, либо быть учтена в акте;
3. составлять акт уничтожения — ч. 4 ст. 21 требует подтверждения факта, а не только самого действия.

[СПОРНО] Практика применения п. 3.1 ч. 2 ст. 19 к обычным СУБД пока не устоялась: буквальное прочтение требует сертифицированного средства для любой операции удаления, что для рядового DELETE в прикладной базе выглядит несоразмерным. Консервативный подход — заложить требование в порядок уничтожения и обсудить с профильным юристом до запуска, а не после первого запроса субъекта.

5. Требования к механизму аутентификации

Реализуются вами, аттестатом провайдера не закрываются.

- хранение паролей — argon2id, не шифрование и не быстрые хеши (MD5, SHA-*);
 - ограничение частоты попыток входа и блокировка после серии неудач;
 - API-ключи хранятся в виде хеша; значение ключа показывается один раз при выдаче; предусмотрен отзыв;
 - разграничение доступа проверяется **на бэкенде**, а не только в интерфейсе: администратор не должен получать данные чужого аккаунта подстановкой идентификатора в запрос;
 - Streamlit-интерфейс (app.py) обращается к бэкенду напрямую, минуя контур авторизации. До запуска он должен быть либо закрыт сетевым доступом как внутренний инструмент, либо переведён на тот же механизм. **Открытый доступ к нему обесценивает всю систему разграничения доступа.**
-

6. Что дополнить в комплекте документов

- [] Перечень обрабатываемых ПДн — добавить категорию учётных записей
 - [] Политика обработки ПДн — раздел о пользователях сервиса
 - [] Уведомление в РКН — обновить (документ 04)
 - [] Модель угроз — добавить угрозы компрометации учётных данных и НСД к чужому аккаунту через нарушение разграничения доступа
 - [] Договор поручения (документ 03) — оговорка о подпользователях (п. 1.1)
 - [] Регламент реагирования на инциденты — сценарий компрометации учётной записи
 - [] Порядок уничтожения — сроки из п. 4
-

7. Чек-лист до выпуска к пользователям

Проверка	Статус
Публичной регистрации нет, только приглашения	☐
БД учётных записей размещена в РФ	☐
Пароли — argon2id	☐
Разграничение доступа проверяется на бэкенде	☐
app.py (Streamlit) закрыт или переведён на авторизацию	☐
mapping на сервере не сохраняется	☐
Договор поручения заключён с каждым аккаунтом	☐
Согласие на обработку при активации приглашения	☐
Уведомление в РКН обновлено	☐

8. Отдельно: до включения онлайн-оплаты

Онлайн-оплата — не только платёжная интеграция. Она подразумевает возможность подключения без предварительного договора, то есть переход к модели, разобранный в разделе 2 документа 09. **До её включения необходимо повторно пройти оценку модели предоставления сервиса**, включая уровень защищённости (вероятный переход с УЗ-3 на УЗ-2) и применимость ст. 16 ЗоЗПП.

Техническая подготовка (таблица quota_grants с полем external_payment_id) ведётся заранее и сама по себе правовых последствий не создаёт.